

Agentory

Backend & External Integration Audit

Date	20 September 2026
Repository	agentory-main-local · branch feat/lead-mission-v2-worker
Commit at audit	7826f88d (local, unpushed) — origin at f2d68270
Method	Static inventory → flow tracing → static verification → bounded live smoke tests
Environment	Local Supabase stack. Production Supabase was not contacted at any point.
Paid spend	≈ US\$0.001 (4 OpenAI calls, 1 Anthropic call, 1 Firecrawl credit)

Scope

Every external provider and provider-calling function in the repository, including calls reached indirectly through shared abstractions rather than direct `fetch()` calls. Coverage: OpenAI, Anthropic, the Lovable/Gemini gateway, Apify, Firecrawl, Resend, Google Calendar, n8n webhooks, Supabase Edge Functions, Company Brain research, lead research and qualification, LinkedIn enrichment, agent execution, scheduled jobs, and the frontend surfaces that call any of them.

An integration was only recorded as working if it was proven, not merely present in the codebase. Where proof required money, the cheapest bounded request was used and the ceiling was stated in advance.

Executive summary

Question	Answer
What genuinely works today	OpenAI (models and strict structured output), Anthropic, Apify actors and dataset retrieval, Firecrawl v2 server-side scraping, Supabase Edge Functions with workspace-scoped writes, founder LinkedIn enrichment, and the lead-mission queue → worker → task → Workbench lifecycle.
What only looks implemented	The Gemini/Lovable model tier (inert), Google Calendar, production cron schedules, radar scanning, and the full lead pipeline under a live model rather than a stub.
What is broken	Company LinkedIn location extraction, Resend email delivery, and the browser-side Firecrawl v1 client.
APIs actively in use	OpenAI, Anthropic, Apify, Firecrawl v2, Supabase — plus n8n webhooks called directly from the browser.
Obsolete	The Gemini model map, edge functions <code>job-feed</code> , <code>mcp</code> and <code>unlock-founders</code> , the unrouted Talent Intelligence page with its four scrapers, and <code>src/lib/firecrawl.ts</code> as a keyed client.

Fix first, in order

1	Browser-bundled Firecrawl key — one production build from a public leak	FIXED 20 Sep
2	Lovable/Gemini routing — six features silently on a fallback model	FIXED 20 Sep
3	Company LinkedIn location normalization — same bug class as the founder fix	FIXED 20 Sep
4	Resend sender domain — outreach email cannot deliver	open
5	OpenAI request timeout — no abort signal on that path	open
6	Delete dead functions and pages so the next audit is smaller	open

Integration matrix

Status as at the audit. Items 1–3 of the priority list were remediated the same day; their post-fix state is shown in the final section.

Provider	Function	Static	Tests	Live	DB	Status
OpenAI	Lead planner / strategist	Y	48	Y — 200	Y	Working
Anthropic	Brain draft, all AI fallback	Y	43	Y — 200	Y	Working
Lovable / Gemini	6 of 7 task types	Configured	Partial	No key	—	Inert
Apify	Actors and datasets	Y	325	Y	Y	Working
Firecrawl v2	Map / scrape (backend)	Y	80	Y — 200	Y	Working
Firecrawl v1	Browser client	Old version	None	No	No	Dead + risk
LinkedIn profile	Founder enrichment	Y	Y (+5)	Y	Y	Working
LinkedIn company	Company enrichment	Shape bug	Partial	No	Partial	Broken
Resend	Scheduled email	Sandbox sender	1	No	Status col	Broken
Google Calendar	OAuth + events	Y	4	No creds	Tokens	Unproven
n8n webhooks	Scraper / CRM pages	Hardcoded	1	No	Partial	Risky
Supabase Edge	24 functions	Y	Y	Y (local)	Y	Working
Cron	Resume / monitoring	Y	Y	Prod only	—	Unproven

Live verification

Each call was the cheapest bounded request that could settle the question.

Provider	Test	Result
OpenAI	gpt-5.6-luna / terra / sol / gpt-4.1-mini, 1 completion each	All HTTP 200. Model identifiers are valid.
OpenAI	Strict json_schema structured output	HTTP 200, returned {"a":1} — the exact mode the execution planner uses.
Anthropic	claude-haiku-4-5-20251001, max_tokens 1	HTTP 200, usage reported.
Firecrawl	POST /v2/scrape of example.com	HTTP 200, 167 chars markdown, metadata parsed.
Apify	2 real actor runs earlier the same day	Succeeded; per-run billing confirmed; not-found rows free.
Resend / Google / n8n	Not called	Side effects or missing credentials — deliberately excluded.

An initial reading of the OpenAI result was wrong and is worth recording: with `max_completion_tokens: 1` the reasoning models returned HTTP 400, which looks like an invalid model identifier. Re-running with headroom returned 200 on every model. The models are valid; the first test was.

Findings

1. Firecrawl API key wired to ship in the browser bundle [HIGH]

`src/lib/firecrawl.ts` read a VITE-prefixed Firecrawl credential. Vite inlines every such value into the JavaScript it ships, and the built artefact already contained the Firecrawl v1 client in the `JobDistribution` chunk — so the code path shipped. The key was absent from that build only because the variable happened to be unset when it ran; it is set in the Railway environment.

Impact	Any production build from that environment publishes the Firecrawl key to every visitor.
Reachable now	Not in the current artefact. One build away.
Fix	Remove the client-side path; route through an Edge Function holding the credential.
Status	Fixed 20 Sep 2026 — verified by building with a canary key

2. Every AI feature silently ran on a fallback model [HIGH]

`aiProvider.ts` mapped six of seven task types to Gemini models behind the Lovable gateway, which requires a credential the running environment does not have. Every Lovable attempt was skipped and all tasks fell through to a single hardcoded helper-grade Anthropic model. Nothing reported it: the call returned success and the model name appeared only in a log.

Impact	Pilot chat, orchestration, agent execution, tool-input planning and both Company Brain tasks ran helper-grade. Chat spend also landed in the ledger as unpriced.
Reachable now	Yes — on every AI feature.
Fix	Remove the dead gateway; assign a deliberate model per task; make a missing credential a loud refusal.
Status	Fixed 20 Sep 2026 — option B adopted

3. Company LinkedIn enrichment silently dropped every office [HIGH]

`companyBrainResearch/companyLinkedIn.ts` read locations with `asStringArray(row.locations)` and looked for a `headquarters` key. The repository's own actor catalog documents the real shape as `locations[{headquarter, parsed.text}]` — an array of objects, with no such key. An array of objects yields nothing, so headquarters and offices were lost while the call reported success.

Impact	Company geography missing from the Company Brain; the same bug class as the founder profile fix.
Reachable now	Yes — onboarding Step 2 whenever a company LinkedIn URL is supplied.
Fix	Read the documented object shape; take the headquarters from the provider's own flag.
Status	Fixed 20 Sep 2026

4. Resend cannot deliver to real recipients [HIGH]

`send-scheduled-emails/index.ts` sends from `onboarding@resend.dev`, Resend's sandbox sender, which only delivers to the account owner's verified address. `RESEND_API_KEY` is also absent from the worker environment, so the function returns HTTP 500 before attempting a send.

Impact	Outreach email is non-functional.
Reachable now	Yes — any scheduled send fails.
Fix	Verified sending domain and a real from-address; then a dev-only send to your own address.
Status	Open

5. Browser calls hardcoded personal n8n webhooks [MEDIUM]

src/services/n8nApi.ts and leadScraperApi.ts post to webhook URLs on a personal domain from four routed, authenticated pages. The URLs are unauthenticated and visible in the bundle.

Impact	Anyone can replay the webhooks; user-facing features depend on single-person infrastructure.
Reachable now	Yes — Lead Scraper, Deep Search, Post Interceptor and Lead CRM are all routed.
Fix	Move behind an Edge Function, or retire the pages.
Status	Open — not smoke-tested, as firing them triggers real workflows

6. No request timeout on the OpenAI path [MEDIUM]

aiProvider.ts bounds its calls with an AbortController. gptProvider.ts has retry and backoff but no abort signal, so a hung connection is bounded only by the caller's own deadline.

Impact	A stalled provider connection can occupy a worker slot for the full mission ceiling.
Reachable now	Yes, under provider degradation.
Fix	Add an AbortSignal timeout consistent with the Anthropic path.
Status	Open

7. Model-spend ceiling fails closed on partial configuration [MEDIUM]

MODEL_SPEND_CEILING_USD and MODEL_SPEND_PERIOD_DAYS must both be positive. Either missing or zero is treated as misconfigured and every model call is refused with HTTP 429 before a task row exists.

Impact	Correct behaviour, but it presents as an unexplained 429 and has already cost a debugging session.
Reachable now	Yes, on any environment configured with only one of the pair.
Fix	Surface the reason in the refusal payload the operator sees.
Status	Documented

Dead and unused

Edge functions	job-feed, mcp, unlock-founders — no references anywhere outside their own directories
Pages	Talent Intelligence is not routed; its four talent scrapers are unreachable
Modules	The competitor scrapers and Add Competitor modal are imported by nothing
Config	The Gemini model map was unreachable without a credential that is not set

Missing credentials

Absent from the worker environment: LOVABLE_API_KEY, RESEND_API_KEY, GOOGLE_CLIENT_ID, GOOGLE_CLIENT_SECRET, GOOGLE_CALENDAR_ID, SEARCH_WEB_API_KEY, APIFY_ENABLE_PEOPLE_SEARCH, APIFY_ACTOR_PEOPLE_SEARCH. Present: OPENAI_API_KEY, ANTHROPIC_API_KEY, APIFY_API_TOKEN, FIRECRAWL_API_KEY, SUPABASE_.*.

Caveat: the Resend and Google functions run on hosted Supabase, whose function secrets are a separate store that was deliberately not queried. The statements above describe the worker environment only.

Test coverage

Suites at audit time: edge-functions 7,527 passing; UI 521; deploy-safety 69. Coverage is heavily skewed — Apify 325 files, Firecrawl 80, OpenAI 48, Anthropic 43, radar 29, against Resend 1, n8n 1 and Calendar 4. The three least-tested integrations are precisely the three with missing credentials and external side effects. No test asserted that a live provider response shape matches its normalizer, which is how findings 3 and the

founder-location bug both survived.

Remediation completed on 20 September 2026

The three highest-risk findings were fixed after the audit was delivered. All suites green afterwards: edge-functions 7,550; UI 526; deploy-safety 69. Twenty-eight tests added. Nothing was committed, pushed or deployed.

Item 1 — Firecrawl browser secret

New	supabase/functions/firecrawl-scraper/index.ts — authenticated, server-side v2 scrape with a 60-second timeout and an SSRF guard
New	_shared/firecrawlRequestGuard.ts — URL and prompt bounds, extracted so they are testable
Changed	src/lib/firecrawl.ts rewritten as a credential-free proxy; crawl and search refuse rather than becoming a paid open proxy
Changed	PlatformCard.tsx (the only live consumer), TalentIntelligence.tsx
Proof	Production build run <i>with</i> a canary key present: canary absent from bundle, no key literal, no api.firecrawl.dev, proxy route present

Item 2 — company LinkedIn normalization

Approach	One shared parser rather than a second implementation: linkedInLocationEntries extracted from the lead pipeline, which already read this shape correctly
Result	Headquarters resolves from the provider's own headquarter flag; all offices survive; industries and founded year now read their object shapes
Safety	Missing or malformed data yields empty rather than guessing. The previous asStringArray fallback was manufacturing offices from junk values and was removed
Contract	enrichedGeography's pinned behaviour is untouched — string entries are opt-in, so the lead pipeline is unchanged

Item 3 — model routing, option B adopted

The Lovable/Gemini gateway was removed rather than revived. Agentory holds its own OpenAI and Anthropic credentials and its lead pipeline already routes OpenAI directly; a reseller gateway in front of the same two vendors had no remaining job. Each task now names the model it intends and the fallback it permits.

Task	Intended model	Provider	Fallback policy
pilot_chat	claude-haiku-4-5	Anthropic	None — refuse
orchestration_plan	claude-haiku-4-5	Anthropic	None — refuse
agent_execution	claude-haiku-4-5	Anthropic	None — refuse
tool_input_planning	claude-haiku-4-5	Anthropic	gpt-4.1-mini (OpenAI)
company_brain_analyze	claude-haiku-4-5	Anthropic	None — refuse
company_brain_followups	claude-haiku-4-5	Anthropic	None — refuse
helper	claude-haiku-4-5	Anthropic	gpt-4.1-mini (OpenAI)

A missing credential with no declared fallback now returns no_provider_for_task naming the environment variable to set. A fallback that does run sets degraded: true with the intended model and emits a warning. No task can quietly run somewhere else.

Which models are paid for was deliberately not changed: every task keeps the model it was actually running, so the change is behaviour-preserving. Upgrading a tier is now a one-line edit per row and a cost decision for the owner.

Residual

Three informational surfaces — tool-availability, integration-readiness and daily-brief — still report the retired gateway as an available provider and will over-report. They are display-only and were left untouched under the instruction not to undertake general cleanup.